🛡️ Post-Quantum Cryptography (PQC) Secure-Code Reviewer Agent

Production DevSecOps & AI Systems Architectural Blueprint

TRACK 1: AGENTIC CYBER DEFENCE | NIST FIPS 203 (ML-KEM) | NIST FIPS 204 (ML-DSA) | ZERO TRUST GATING | SHA-256 CHAINED AUDITING

Executive Architectural Summary: The PQC Secure-Code Reviewer is an agentic cybersecurity static analysis platform designed to remediate the existential threat of "*Harvest Now, Decrypt Later*" *(HNDL)* attacks. It couples deterministic Abstract Syntax Tree (AST) scanning with transparent Chain-of-Thought (CoT) reasoning, enforces non-negotiable Human-in-the-Loop (HITL) approval gates, and guarantees cryptographic non-repudiation using recursive SHA-256 hash chaining.

1. Threat Modeling & Cryptographic Risk Analysis

Modern enterprise architectures rely fundamentally on public-key cryptography for digital signatures and key agreement. On a Cryptographically Relevant Quantum Computer (CRQC), Shor's algorithm solves discrete logarithms and integer factorizations in polynomial time $\mathcal{O}((\log N)^3)$, rendering classical asymmetric cryptography completely insecure.

Algorithm	Category	Quantum Attack Vector	Impact	NIST PQC Replacement	Target Standard
RSA (2048/4096)	Key Exchange / Signature	Shor's Algorithm	Total Compromise (Polynomial Time)	ML-KEM-768 / ML-DSA-65	FIPS 203 / 204
ECDSA / ECDH	Signatures / Key Exchange	Shor's Algorithm (ECDLP)	Total Compromise (Forged Signatures)	ML-DSA-65 / ML-KEM-768	FIPS 204 / 203
DSA / DH	Key Exchange / Signature	Shor's Algorithm	Total Compromise	ML-KEM-768 / ML-DSA-65	FIPS 203 / 204
AES-128 / CBC	Symmetric Encryption	Grover's Algorithm	Effective security halved to 64-bit	AES-256-GCM	NIST SP 800-38D
MD5 / SHA-1	Hashing	Classical Collisions + Grover	Critically Broken	SHA-3-256 / SHA-512	FIPS 202

2. Four-Tier Production System Architecture

The system is organized into four distinct architectural tiers ensuring strict separation of concerns, least privilege, and deterministic reproducibility:

ENTERPRISE ARCHITECTURE TIERS

Tier 1: Shift-Left & Ingestion

- Streamlit Web Dashboard (Port 8501)
- Headless DevSecOps CLI (`pqc_agent/cli.py`)
- Git Pre-Commit Hook (`.pre-commit-config.yaml`)

Tier 2: Agentic State Engine

- LangGraph 5-Node State Machine
- State Checkpointer (`MemorySaver` / DB)
- Zero-Trust HITL Gate (`interrupt()`)

Tier 3: Analysis & Synthesis

- Python AST Scanner & Java Syntax Trees
- AI Reasoning Core (Gemini 1.5 Pro + CoT)
- FIPS 203/204 Patch Synthesizer

Tier 4: Provenance & Governance

- Enterprise Policy Engine (`pqc_config.yaml`)
- SHA-256 Recursive Tamper-Evident Hash Chain
- JSON & TXT Audit Outputs (`audit_outputs/`)

3. LangGraph Five-Node Execution Pipeline

The core workflow is governed by a stateful LangGraph Directed Acyclic Graph (DAG) with explicit Human-in-the-Loop gating:



1. **INGEST**: Evaluates source payloads, auto-detects dialect (Python/Java), logs file characteristics, and initializes state.
2. **SCAN**: Executes deterministic static analysis. Uses Python's native `ast.parse` to traverse import nodes and call sites, and regex pattern engines for Java source. Generates confidence ratings (0.95 for direct imports, 0.85 for call sites).
3. **INVESTIGATE**: Synthesizes NIST-standard migration patches. Generates Chain-of-Thought (CoT) reasoning outlining Shor's vs. Grover's threats, surfaces explicit uncertainty metrics, and includes fallback rule engines when offline.
4. **HUMAN APPROVAL (HITL Gate)**: Halts execution completely using LangGraph's `interrupt()` primitive. Resumes exclusively via `Command(resume={"decision": "approved", "feedback": "..."})`. The agent is mathematically incapable of committing code autonomously.
5. **FINALISE**: Seals approved patches, records reviewer authorization, calculates the terminal SHA-256 chain hash, and writes persistent audit logs.

4. DevSecOps CI/CD Integration & Shift-Left Gates

Security must shift left directly into developer workflows. The project provides multiple enforcement mechanisms:

4.1 Automated CLI Scanner Engine (`pqc_agent/cli.py`)

Enables headless execution inside CI/CD runners, container builds, and pre-commit hooks:

```
python -m pqc_agent.cli --target src/ --config pqc_config.yaml --fail-on CRITICAL --generate-patches --out
```

- **Exit Code 0**: Compliance verification passed. Clean codebase.
- **Exit Code 1**: Policy violation. Flagged cryptographic primitives $\ge$ threshold (e.g. CRITICAL RSA). *Fails the CI build.*
- **Exit Code 2**: Invocation or syntax error.

4.2 Continuous Security Workflows (`.github/workflows/`)

- `ci.yml` : Validates syntax, executes unit test suites (`test_pqc_agent.py`), and proves LangGraph interrupt & resume cycles (`test_graph_e2e.py`).
- `security-scan.yml` : Executes SAST (Bandit), dependency audit (pip-audit), and the automated PQC security gate. Uploads the tamper-evident JSON audit trail as a workflow artifact.

- `.pre-commit-config.yaml`: Local git hook preventing developers from committing deprecated crypto locally.

5. Cryptographic Tamper-Evident Hash Chaining

To satisfy strict compliance regimes (SOC 2 Type II, NIST SP 800-53), audit records are cryptographically linked using SHA-256:

$$\text{ChainHash}_0 = \text{SHA256}(\text{"0"} \times 64)$$
$$\text{ChainHash}_i = \text{SHA256}(\text{CanonicalJSON}(\text{Entry}_i) \,||\, \text{ChainHash}_{i-1})$$

Every historical log entry forms a link in the chain. Any alteration to a finding, confidence score, reviewer feedback, or timestamp immediately breaks the terminal hash, exposing unauthorized tampering.

6. Regulatory Compliance & Standards Alignment

Regulatory Standard	Control ID	Requirement	PQC Reviewer Implementation
NIST SP 800-53 Rev. 5	SC-13	Cryptographic Protection	Detects sub-128-bit quantum primitives; migrates to FIPS 203/204.
NIST SP 800-53 Rev. 5	AU-10	Non-Repudiation	SHA-256 chained hashing proves provenance of all human approvals.
SOC 2 Type II	CC6.1 / CC6.6	Logical Access & Boundary Defense	Zero-Trust Human-in-the-Loop approval gate prior to code commit.
NSA CNSA 2.0	Timeline	PQC Migration Mandates	Facilitates transition to ML-KEM/ML-DSA ahead of 2030 deadlines.